Consigna Práctica 2: Mitigación de Vulnerabilidades de CWE

Introducción

Se le brinda un conjunto de programas con vulnerabilidades.
El código fuente se encuentra en https://github.com/ucudal/2026-Desarrollo-Seguro.
Salvo que se especifique lo contrario, la rama a utilizar es **main**.

El código actual posee por lo menos las siguientes vulnerabilidades:

1. Ejercicio 1 - Inyección SQL (SQLi).
2. Ejercicio 2 - Cross Site Scripting (XSS).
3. Ejercicio 3 – File Upload.
4. Ejercicio 4 – Server Side Template Injection.
5. Ejercicio 5 - Almacenamiento inseguro.

Se solicita

- Crear un repositorio a partir del repositorio template.
- Generar una rama (branch) denominada **practico-2** con las mitigaciones de las vulnerabilidades. No se debe modificar la rama **main**.
- El repositorio será individual y privado. Se le deberá dar permisos exclusivamente a los profesores.

Entregables

I. Generar una prueba de concepto (PoC) para cada vulnerabilidad: explicar paso a paso cómo explotar la vulnerabilidad y qué datos ingresar para explotarla.
II. Implementar la mitigación: Realizar modificaciones en el código fuente de forma que se elimine la vulnerabilidad en la rama **practico-2**.
III. Generar un informe que detalle los hallazgos, y las PoC de cada uno. Este informe debe denominarse *Practico2.md* y debe encontrarse en la rama **practico-2**.
IV. La entrega se realiza en un repositorio de GitHub **PRIVADO** con acceso de lectura al grupo *desarrollo-seguro-profesores*[1]
V. Se debe entregar el link al reposiorio en la WebAsignatura. No deben realizarse cambios en la rama de entrega luego de la fecha de fin del práctico. Realizar cambios implica la quita de puntos.

[1] https://github.com/orgs/ucudal/teams/desarrollo-seguro-profesores

Evaluación

El trabajo entregado será evaluado considerando los siguientes aspectos:

- Correctitud.
- Completitud.
- Profundidad y detalle.
- Presentación.

Recomendaciones

Se recomienda fuertemente realizar el práctico dentro del ambiente generado en el práctico 1.
Se recomienda utilizar los archivos docker-compose.yml para la ejecución.
El estudiante puede utilizar AI para realizar las mitigaciones. Es importante destacar que el estudiante será responsable de defender su trabajo oralmente. No comprender el código entregado de forma cabal puede comprometer fuertemente la aprobación del práctico.